EXAMEN SC-200 · ENTRAÎNEMENT EN CONDITIONS RÉELLES

CORRIGÉS DES EXAMENS BLANCS

Guide complet de préparation à la certification Microsoft SC-200

3 examens de 50 questions · vérification documentaire : 2026-10-12

Examen blanc n° 1 — corrigé

Corrigé de l'examen blanc n° 1

Chaque question de cet examen est une reprise d'une question du guide (numéro indiqué) ; les propositions ont été mélangées. Elle n'est pas comptée une seconde fois dans le total des questions uniques.

N°	Réponse	Justification
1	**D**	« Attack Disruption » = attaque contenue, pas terminée : enquêter, éradiquer, puis lever le confinement. Bonne(s) réponse(s) : Prioriser l'incident, analyser l'histoire de l'attaque, poursuivre l'investigation et la remédiation, puis lever le confinement et réactiver le compte une fois la menace éliminée. — détails : question n° 118 du guide.
2	**B**	Playbook automatique sur incident = déclencheur « Microsoft Sentinel incident ». Bonne(s) réponse(s) : Le déclencheur Microsoft Sentinel « Microsoft Sentinel incident ». — détails : question n° 53 du guide.
3	**A**	Alertes Insider Risk : pseudonymisation possible ; coordination RH/juridique. Bonne(s) réponse(s) : Parce que les paramètres de confidentialité d'Insider Risk Management peuvent masquer les noms des utilisateurs pour protéger la vie privée, seuls des rôles autorisés pouvant lever la pseudonymisation. — détails : question n° 172 du guide.
4	**B**	Détection personnalisée : Timestamp/TimeGenerated + DeviceId + ReportId (tables MDE) ; 150 alertes max par exécution. Bonne(s) réponse(s) : Timestamp (ou TimeGenerated), ainsi que DeviceId et ReportId pour les tables Defender for Endpoint. — détails : question n° 174 du guide.
5	**D**	union = concaténation ; withsource = colonne du nom de table ; isfuzzy=true tolère les tables manquantes. Bonne(s) réponse(s) : Le nom de la table d'origine de chaque ligne (SigninLogs ou AADNonInteractiveUserSignInLogs). — détails : question n° 192 du guide.
6	**A**	Mouvement latéral = dcount(cibles) élevé par compte sur une fenêtre courte. Bonne(s) réponse(s) : Le compte j.roux, qui s'est connecté à 5 serveurs différents (dont un contrôleur de domaine) en un peu plus de 2 minutes. — détails : question n° 262 du guide.
7	**A**	Règles de transfert malveillantes = OfficeActivity (New-InboxRule/Set-InboxRule, ForwardTo/RedirectTo) ; bloquer le transfert externe par stratégie. **Explication complémentaire :** Le journal d'audit unifié Microsoft 365 (connecteur Office 365 → **OfficeActivity**) enregistre les opérations Exchange comme **New-InboxRule**, **Set-InboxRule** ou **UpdateInboxRules** (Outlook), avec les paramètres (ForwardTo, RedirectTo, ForwardAsAttachmentTo, DeleteMessage…). Bonne(s) réponse(s) : ```kql — détails : question n° 131 du guide.
8	**B**	Libérer après vérification (AV, chasse IOC, identifiants) puis surveiller de près. Bonne(s) réponse(s) : Vérifier qu'aucune activité malveillante ne persiste (analyse antivirus complète, chasse sur les IOC de l'incident, état de l'enquête automatisée), que les identifiants de l'utilisateur ont été réinitialisés si nécessaire, puis libérer et surveiller. — détails : question n° 331 du guide.
9	**D**	Quels e-mails l'attaquant a-t-il lus ? = MailItemsAccessed (Bind/Sync), dans Purview Audit / CloudAppEvents. **Explication complémentaire :** **MailItemsAccessed** enregistre l'accès aux messages par les protocoles de messagerie et clients (accès « Bind » à un élément précis, ou « Sync » pour une synchronisation de dossier). Il permet d'évaluer l'étendue d'une violation de données dans une boîte compromise. Bonne(s) réponse(s) : MailItemsAccessed. — détails : question n° 168 du guide.
10	**A**	Activités SharePoint/OneDrive/Exchange dans Sentinel = OfficeActivity (Operation, OfficeWorkload, OfficeObjectId). Bonne(s) réponse(s) : ```kql — détails : question n° 173 du guide.
11	**C**	Trouver les appareils non protégés = device discovery (mode standard) via les appareils déjà intégrés. Bonne(s) réponse(s) : La découverte des appareils (device discovery), en mode standard, qui utilise les appareils intégrés à MDE pour sonder et identifier les appareils non gérés. — détails : question n° 99 du guide.

N°	Réponse	Justification
12	B	Logique de référence historique = règle planifiée (lookback ≤ 14 jours) avec entités mappées. **Explication complémentaire :** Une **règle planifiée** permet une logique de **référence** (pays connus sur 14 jours, via une fenêtre de recherche adaptée) et le filtrage sur `DeviceDetail.isCompliant`. Le **mappage d'entités** permet la corrélation et l'automatisation. Bonne(s) réponse(s) : Une règle planifiée (par exemple toutes les heures, avec une référence de 14 jours dans la requête), avec mappage des entités Account et IP et regroupement des alertes par utilisateur. — détails : question n° 420 du guide.
13	D	Conservation longue + accès occasionnel = niveau data lake (jusqu'à 12 ans), interrogé par KQL ou jobs KQL. Bonne(s) réponse(s) : Stocker la table dans le niveau data lake avec une rétention de 7 ans, et utiliser des requêtes KQL ou des jobs KQL lors des investigations. — détails : question n° 26 du guide.
14	B	Sans agent = évaluation par instantanés de disques (vulnérabilités, secrets, malware), sans impact sur la VM. Bonne(s) réponse(s) : Elle évalue les vulnérabilités, l'inventaire logiciel, les secrets et les malwares à partir d'instantanés de disques, sans installer ni gérer d'agent et sans impact sur les performances de la VM. — détails : question n° 363 du guide.
15	A	Ce qu'une app/compte a fait via l'API Graph = MicrosoftGraphActivityLogs (ou GraphApiAuditEvents en chasse avancée). Bonne(s) réponse(s) : Les journaux d'activité Microsoft Graph (table MicrosoftGraphActivityLogs), envoyés vers Log Analytics par paramètres de diagnostic Entra ID. — détails : question n° 170 du guide.
16	D	E-mail ↔ clic = NetworkMessageId (+ RecipientEmailAddress = AccountUpn). Bonne(s) réponse(s) : ```kqlx — détails : question n° 237 du guide.
17	B	Incidents liés non corrélés → déplacer les alertes / fusionner manuellement, avec un commentaire. Bonne(s) réponse(s) : Déplacer les alertes de l'un vers l'autre (ou fusionner les incidents manuellement selon l'expérience disponible) afin de centraliser l'investigation. — détails : question n° 81 du guide.
18	D	Attack disruption = confinement natif automatique Defender XDR ; playbook = automatisation personnalisée Logic Apps. Bonne(s) réponse(s) : L'interruption automatique est une capacité intégrée de Defender XDR qui contient automatiquement des actifs compromis (appareil, utilisateur) lors d'attaques à haute confiance, alors qu'un playbook est un workflow Logic Apps conçu et maintenu par le SOC. — détails : question n° 60 du guide.
19	A	Données de référence évolutives (VIP, actifs critiques, exclusions) = watchlist + `_GetWatchlist('alias')`. Bonne(s) réponse(s) : Importer la liste comme watchlist et l'utiliser dans les requêtes des règles via `_GetWatchlist('alias')`, par exemple pour joindre sur le nom d'hôte et ajuster la gravité. — détails : question n° 67 du guide.
20	D	Inter-espaces : `workspace("nom").Table` + `union` ; l'accès dépend des droits sur chaque espace. Bonne(s) réponse(s) : Utiliser `union` avec la fonction `workspace()` pour interroger la table SigninLogs de chaque espace dans la même requête. — détails : question n° 6 du guide.
21	A	Identité → actions Azure : SigninLogs.IPAddress ↔ AzureActivity.CallerIpAddress + fenêtre temporelle. **Explication complémentaire :** **AzureActivity.CallerIpAddress** et **SigninLogs.IPAddress** relient l'authentification et les actions. La contrainte temporelle limite la corrélation à la période d'exploitation de la session. Bonne(s) réponse(s) : ```kql — détails : question n° 248 du guide.
22	B	Exécuter sans modifier = Playbook Operator ; modifier = Logic App Contributor ; permettre à Sentinel d'appeler les playbooks = Automation Contributor (compte de service). Bonne(s) réponse(s) : Microsoft Sentinel Playbook Operator. — détails : question n° 10 du guide.
23	D	DCSync depuis une machine non-DC = vol d'identifiants massif probable (dont krbtgt) → priorité maximale. **Explication complémentaire :** **DCSync** (T1003.006) utilise les droits « Replicating Directory Changes (All) » pour demander à un DC les données de mots de passe via le protocole de réplication (DRSUAPI). Depuis une machine qui n'est pas un DC, c'est un indicateur fort de compromission d'un compte à privilèges. Bonne(s) réponse(s) : Un acteur imite un contrôleur de domaine pour demander la réplication des secrets (hachages de mots de passe, dont celui de krbtgt), ce qui permet le vol massif d'identifiants et la création de Golden Tickets. — détails : question n° 138 du guide.
24	C	Vision d'ensemble d'une vague d'hameçonnage = Campaigns (MDO P2). Bonne(s) réponse(s) : Les vues de campagnes (Campaigns). — détails : question n° 133 du guide.

N°	Réponse	Justification
25	C	Faux positif connu = règle de suppression ciblée (type d'alerte + entités + expiration). Bonne(s) réponse(s) : Créer une règle de suppression d'alertes limitée au type d'alerte concerné, à l'IP du prestataire et éventuellement à une date d'expiration. — détails : question n° 377 du guide.
26	C	SQL sur VM : Defender for SQL (moteur SQL) + Defender for Servers (OS). Bonne(s) réponse(s) : Defender for SQL servers on machines (plan Defender for SQL couvrant les serveurs SQL sur machines). — détails : question n° 391 du guide.
27	B	Abus d'API publiées via API Management = Defender for APIs. Bonne(s) réponse(s) : Defender for APIs. — détails : question n° 401 du guide.
28	B	UEBA = paramètre à activer + synchronisation d'annuaire + sources ; résultats dans BehaviorAnalytics et IdentityInfo. Bonne(s) réponse(s) : Activer l'UEBA dans les paramètres de Sentinel, synchroniser l'annuaire (Microsoft Entra ID et éventuellement Active Directory via Defender for Identity) et sélectionner les sources de données (par exemple journaux de connexion, journaux d'audit, Azure Activity, événements de sécurité). — détails : question n° 65 du guide.
29	A	Trop d'incidents pour une même attaque = regroupement d'alertes par entités. Bonne(s) réponse(s) : Le regroupement des alertes en incidents par entités correspondantes (Host et Account) sur une fenêtre de quelques heures. — détails : question n° 425 du guide.
30	D	Exception temporaire et ciblée = règle d'automatisation (conditions précises + fermeture + expiration). Bonne(s) réponse(s) : Une règle d'automatisation déclenchée à la création d'un incident, conditionnée à la règle d'analyse concernée et à l'entité IP 10.10.5.20, qui ferme l'incident avec la classification adéquate, et dotée d'une date d'expiration. — détails : question n° 51 du guide.
31	B	Menaces sur les applications d'IA générative = protection des charges d'IA de Defender for Cloud. Bonne(s) réponse(s) : La protection contre les menaces pour les charges de travail d'IA (Defender for AI services). — détails : question n° 371 du guide.
32	B	Incident → alertes : mv-expand AlertIds puis jointure sur SystemAlertId (après arg_max). Bonne(s) réponse(s) : ```kql — détails : question n° 241 du guide.
33	C	RDP exposé = supprimer l'exposition (VPN/MFA, Bastion, JIT) + LAPS ; changer le port ne suffit pas. Bonne(s) réponse(s) : Supprimer l'exposition directe de RDP (accès via VPN/passerelle avec MFA ou accès juste-à-temps), et renforcer/gérer les comptes locaux (LAPS, mots de passe uniques). — détails : question n° 313 du guide.
34	C	Intégration ITSM = playbook Logic Apps + règle d'automatisation ; Logic Apps fournit les connecteurs. Bonne(s) réponse(s) : Un playbook Logic Apps (déclencheur incident) utilisant le connecteur ServiceNow, lancé par une règle d'automatisation filtrée sur la gravité élevée, qui ajoute ensuite un commentaire à l'incident. — détails : question n° 59 du guide.
35	A	Préserver les données Microsoft 365 pour le juridique = conservation eDiscovery (Purview). **Explication complémentaire :** Les **conservations eDiscovery** (Purview) préservent le contenu (y compris les éléments supprimés ou modifiés) des emplacements désignés tant que la conservation est active, ce qui garantit l'**intégrité des preuves** pour une procédure. Bonne(s) réponse(s) : Une conservation (hold) dans un dossier Microsoft Purview eDiscovery, appliquée aux boîtes aux lettres et sites OneDrive concernés. — détails : question n° 329 du guide.
36	D	`bin(TimeGenerated, 1h)` pour les séries temporelles ; bin s'applique à des nombres ou des dates. Bonne(s) réponse(s) : `bin()` doit s'appliquer à la colonne temporelle : `by UserPrincipalName, bin(TimeGenerated, 1h)`. — détails : question n° 212 du guide.
37	C	LOLBins (rundll32, mshta, regsvr32) + javascript:/script:http = exécution détournée (T1218). Bonne(s) réponse(s) : La ligne de PC-44 : rundll32.exe exécutant du JavaScript via mshtml et chargeant un scriptlet distant. — détails : question n° 265 du guide.
38	D	Création (4720) puis ajout à un groupe (4732) rapprochés dans le temps = persistance par compte local. **Explication complémentaire :** **4720** = création d'un compte utilisateur ; **4732** = ajout d'un membre à un groupe local de sécurité. La jointure par ordinateur, la contrainte temporelle `between (CreationTime .. Bonne(s) réponse(s) : ```kql — détails : question n° 218 du guide.
39	A	Spraying réussi = dcountif(échecs) élevé + make_set_if(succès) non vide par IP. **Explication complémentaire :** **dcountif()** compte les comptes distincts en échec (50126) ; **make_set_if()** collecte les comptes ayant réussi depuis la même IP. Le filtre final isole les IP qui ont pulvérisé **et** obtenu au moins un succès, cas prioritaire (compte probablement compromis). Bonne(s) réponse(s) : ```kql — détails : question n° 226 du guide.

N°	Réponse	Justification
40	**A, E**	Automatisation fiable = identités managées à moindre privilège + traçabilité + gestion « as code ». Bonne(s) réponse(s) : Utiliser des identités managées avec le moindre privilège et journaliser les actions des playbooks (commentaires dans l'incident). / Versionner et déployer les playbooks et règles d'automatisation via un dépôt (Repositories / CI-CD), avec tests sur un environnement de développement. — détails : question n° 451 du guide.
41	**C**	SPF/DKIM/DMARC en échec + domaine d'enveloppe étranger = usurpation ; vérifier les exceptions qui ont permis la remise. Bonne(s) réponse(s) : Il s'agit très probablement d'une usurpation (spoofing) du domaine contoso.com ; il faut vérifier pourquoi le message a été remis (stratégie DMARC, exceptions ou règles de transport). — détails : question n° 291 du guide.
42	**A**	Fusion = ML multi-étapes, activé par défaut, logique non modifiable, peu d'incidents mais très fiables. Bonne(s) réponse(s) : Elle s'appuie sur l'apprentissage automatique pour corréler des alertes et anomalies de faible fidélité provenant de plusieurs produits en incidents multi-étapes de haute fidélité ; elle est activée par défaut. — détails : question n° 44 du guide.
43	**C**	Exposition × activité = DeviceTvmSoftwareVulnerabilities ⋈ AlertEvidence sur DeviceId. Bonne(s) réponse(s) : ```kqlx — détails : question n° 247 du guide.
44	**A**	Playbook jamais exécuté = autorisations du service Sentinel, déclencheur, conditions/expiration de la règle. Bonne(s) réponse(s) : Les autorisations du compte de service Microsoft Sentinel (Microsoft Sentinel Automation Contributor) sur le groupe de ressources du playbook, et le type de déclencheur du playbook (incident). — détails : question n° 447 du guide.
45	**B**	Automatisation native sur alertes/recommandations Defender for Cloud = workflow automation (Logic Apps). Bonne(s) réponse(s) : L'automatisation des workflows (workflow automation) de Defender for Cloud, qui déclenche une Logic App selon des conditions sur les alertes. — détails : question n° 378 du guide.
46	**C, D**	Exfiltration cloud personnelle = Cloud Discovery (MDCA/MDE) + audit Microsoft 365 + DLP. Bonne(s) réponse(s) : Cloud Discovery / Defender for Cloud Apps (applications cloud utilisées et volumes de chargement depuis les postes MDE). / Les journaux Microsoft 365 (Purview Audit, CloudAppEvents) pour les téléchargements massifs depuis SharePoint/OneDrive avant le transfert. — détails : question n° 316 du guide.
47	**A**	Règle cachée = nom court + mots-clés financiers + RSS Feeds / suppression / lu. Bonne(s) réponse(s) : La règle de s.lambert : nom « .. », mots-clés financiers, déplacement vers « RSS Feeds » et marquage comme lu. — détails : question n° 267 du guide.
48	**D**	« AUTO DISABLED » = échecs permanents ; corriger la cause, réactiver, et surveiller via SentinelHealth. **Explication complémentaire :** Lorsqu'une règle planifiée échoue de façon **permanente** (erreur non transitoire répétée : table inexistante, fonction supprimée, autorisations perdues sur un espace interrogé…), Sentinel la **désactive automatiquement** et ajoute le préfixe **AUTO DISABLED** à son nom, avec la raison dans la description. Bonne(s) réponse(s) : Sentinel a désactivé la règle après des échecs permanents d'exécution (par exemple une table ou une fonction supprimée, ou une perte d'accès à un espace cible). — détails : question n° 43 du guide.
49	**A**	Chasse avancée XDR = 30 jours par défaut ; pour plus, prolonger la rétention des tables XDR via Sentinel (Analytics ou data lake), à anticiper. Bonne(s) réponse(s) : Configurer, dans la gestion des tables du portail Defender (Sentinel connecté), une rétention plus longue pour la table XDR concernée, dans le niveau Analytics ou data lake. — détails : question n° 27 du guide.
50	**A**	Bruit connu et légitime = alert tuning ciblé, jamais d'exclusion antivirus globale. Bonne(s) réponse(s) : Créer une règle d'ajustement des alertes (alert tuning) qui masque ou résout automatiquement les alertes correspondant à des conditions précises (titre, appareils, ligne de commande ou processus parent). — détails : question n° 79 du guide.

Le score obtenu à cet examen blanc est un indicateur d'entraînement : il ne constitue en aucun cas une prédiction du résultat à l'examen officiel, dont le format, la pondération et la notation (score minimal de 700 sur 1000) sont définis par Microsoft.

Examen blanc n° 2 — corrigé

Corrigé de l'examen blanc n° 2

Chaque question de cet examen est une reprise d'une question du guide (numéro indiqué) ; les propositions ont été mélangées. Elle n'est pas comptée une seconde fois dans le total des questions uniques.

N°	Réponse	Justification
1	**C**	Confirm user compromised (MDCA) → risque utilisateur élevé dans Entra ID Protection. Bonne(s) réponse(s) : « Confirmer que l'utilisateur est compromis » (Confirm user compromised). — détails : question n° 151 du guide.
2	**C**	IOC = réaction rapide mais éphémère ; TTP = détection durable. Bonne(s) réponse(s) : Parce que l'attaquant peut changer facilement de hachage ou d'adresse IP, alors que modifier ses techniques (par exemple sa façon de voler des identifiants ou de se déplacer) lui coûte beaucoup plus cher. — détails : question n° 350 du guide.
3	**C**	SIEM Sentinel = RBAC Azure ; data lake Sentinel = RBAC Microsoft Entra ID (en complément). **Explication complémentaire :** La documentation « Rôles et autorisations dans la plateforme Microsoft Sentinel » précise que Sentinel utilise le **RBAC Azure** pour le SIEM et le **RBAC Microsoft Entra ID** pour le data lake. Par exemple, Reader et Contributor permettent des requêtes interactives sur les espaces ; d'autres opérations (jobs, gestion) exigent des rôles Entra appropriés. Bonne(s) réponse(s) : Le data lake utilise des rôles Microsoft Entra ID (RBAC Entra) en plus des rôles Azure de Sentinel, alors que le SIEM Sentinel repose sur le RBAC Azure. — détails : question n° 14 du guide.
4	**D**	Décoder la commande (`base64_decode_tostring` ou Copilot) pour obtenir de nouveaux IOC. **Explication complémentaire :** La commande encodée se décode en KQL (`extract` + `base64_decode_tostring`) ou avec l'**analyse de script** de Copilot. Elle révèle souvent l'URL de téléchargement de la seconde charge, des domaines et des techniques (contournement d'AMSI, désactivation de la journalisation). Bonne(s) réponse(s) : Extraire la chaîne avec `extract()` puis la décoder avec `base64_decode_tostring()` (en tenant compte de l'encodage UTF-16LE), ou utiliser l'analyse de script de Copilot dans Defender. — détails : question n° 409 du guide.
5	**C**	Après incident : détections ciblées sur IOC et surtout TTP + surveillance des actifs touchés. Bonne(s) réponse(s) : Créer des détections ciblées temporaires (règles analytiques ou détections personnalisées) sur les IOC et TTP observés (IP, domaines, hachages, comptes, techniques) avec une gravité élevée, et une liste de surveillance des actifs touchés. — détails : question n° 335 du guide.
6	**C, D**	Pass-the-hash : changer le mot de passe + traiter la source + réduire l'exposition (tiering, Protected Users, Credential Guard). **Explication complémentaire :** Le **pass-the-hash** (T1550.002) réutilise le hachage NTLM volé (souvent depuis LSASS) pour s'authentifier sans mot de passe. Il faut changer le mot de passe (nouveau hachage), traiter le poste source et réduire l'exposition des identifiants à privilèges. Bonne(s) réponse(s) : Réduire l'exposition des identifiants : limiter les connexions d'administrateurs sur les postes (modèle de niveaux), Credential Guard, LAPS, groupe Protected Users. / Réinitialiser le mot de passe du compte dont le hachage est utilisé et investiguer le poste source (vol de LSASS). — détails : question n° 320 du guide.
7	**A**	Live Response : droits « basiques » (lecture) vs « avancés » (fichiers, scripts, remédiation) à attribuer par rôle. **Explication complémentaire :** Les droits Live Response sont gérés par des **rôles** (RBAC MDE ou RBAC unifié) : **de base** (commandes d'investigation en lecture : `processes`, `connections`, `dir`, `registry`, `services`, `scheduledtasks` …) ou **avancés** (`getfile`, `putfile`, `run`, `remediate` …). Bonne(s) réponse(s) : Lui attribuer un rôle personnalisé n'autorisant que les commandes Live Response de base (sans la permission « advanced »). — détails : question n° 101 du guide.
8	**C**	Téléchargements Microsoft 365 = CloudAppEvents (RawEventData pour le détail des objets). **Explication complémentaire :** **CloudAppEvents** contient les activités Microsoft 365 ; les téléchargements (FileDownloaded, synchronisations) et les détails de l'objet sont dans **RawEventData** (dynamique), d'où l'extraction de SiteUrl et SourceFileName. Bonne(s) réponse(s) : ```kqlx — détails : question n° 433 du guide.

N°	Réponse	Justification
9	**C**	Titre/gravité/tactique dynamiques = alert details override (`{{Colonne}}`) ; données métier dans l'alerte = custom details. Bonne(s) réponse(s) : Le remplacement des détails d'alerte (alert details override), avec un format de nom d'alerte contenant des paramètres tels que `{{SubjectUserName}}` et `{{Computer}}` . — détails : question n° 40 du guide.
10	**A**	Usage d'une clé de stockage volée = StorageBlobLogs (AuthenticationType AccountKey), invisible dans SigninLogs. **Explication complémentaire :** L'usage d'une **clé de compte** ne génère pas de connexion Entra ID : seuls les **journaux de ressources** du stockage (StorageBlobLogs, `AuthenticationType` = AccountKey, `CallerIpAddress`) le révèlent. Defender for Storage peut aussi avoir généré des alertes d'accès anormal. Bonne(s) réponse(s) : Examiner les journaux de ressources du compte de stockage (StorageBlobLogs) pour les accès authentifiés par clé de compte depuis des IP inhabituelles après l'heure de lecture du secret. — détails : question n° 445 du guide.
11	**D**	Consentement illicite : révoquer les octrois et le principal de service — changer le mot de passe ne suffit pas. **Explication complémentaire :** Le **consentement illicite** (T1528) donne à l'application des **jetons** d'accès aux données. La réponse consiste à **révoquer les octrois** (OAuth2PermissionGrants), **désactiver/supprimer le principal de service**, examiner ce que l'application a fait (MicrosoftGraphActivityLogs, audit) et **restreindre le consentement** (éditeurs vérifiés, flux de demande de consentement administrateur). Bonne(s) réponse(s) : Identifier l'application et les utilisateurs ayant consenti, révoquer les autorisations (supprimer les octrois de consentement et désactiver ou supprimer le principal de service), puis restreindre le consentement des utilisateurs. — détails : question n° 296 du guide.
12	**A**	URBAC : incidents/cas = Security Data (Read/Manage) ; tables et rétention = Data (manage) ; configuration = Security settings. Bonne(s) réponse(s) : « Security data » en lecture et gestion (Security Data Read / Security Data Manage) dans le groupe d'autorisations Opérations de sécurité. — détails : question n° 15 du guide.
13	**C**	Faux positif d'interruption sur un compte critique = exclusion ciblée dans les paramètres d'attack disruption. **Explication complémentaire :** Les paramètres de l'interruption automatique permettent d'**exclure des utilisateurs** (et des appareils selon les actions) des actions automatiques de confinement, pour protéger des comptes critiques. Bonne(s) réponse(s) : Ajouter le compte aux exclusions de l'interruption automatique d'attaque (exclusion d'identité), après validation que son comportement est légitime. — détails : question n° 121 du guide.
14	**D, E**	Attack disruption efficace = MDE largement déployé (bloc EDR, anti-falsification) + MDI sur les DC + automatisation suffisante ; exclusions possibles. **Explication complémentaire :** L'interruption automatique repose sur la couverture XDR : **MDE** (découverte des appareils, EDR en mode bloc, protection contre les falsifications) pour **contenir les appareils**, et **MDI** pour **désactiver/contenir les comptes** Active Directory. Les niveaux d'automatisation appropriés et l'audit des exclusions sont également recommandés. Bonne(s) réponse(s) : Déployer Defender for Identity sur les contrôleurs de domaine (pour permettre les actions sur les comptes Active Directory, comme la désactivation de l'utilisateur). / Déployer Defender for Endpoint avec la découverte des appareils et le mode bloc EDR / la protection contre les falsifications, sur un maximum d'appareils. — détails : question n° 117 du guide.
15	**A**	Éradication d'un compte cloud : vérifier consentements OAuth, méthodes MFA, appareils et règles ajoutés. **Explication complémentaire :** Les attaquants créent des **persistances** indépendantes du mot de passe : **consentements OAuth** (T1528), **méthodes MFA** ajoutées, **appareils** enregistrés, **règles** de boîte. L'éradication doit les inventorier (AuditLogs : « Consent to application », « Add OAuth2PermissionGrant », « User registered security info »...) et les supprimer. Bonne(s) réponse(s) : L'inventaire des applications ayant reçu un consentement de l'utilisatrice (et des secrets/identifiants d'application ajoutés) pendant la compromission, avec révocation des octrois illégitimes. — détails : question n° 405 du guide.
16	**C**	Tunnel DNS = sous-domaines longs et uniques vers un même domaine parent. **Explication complémentaire :** Le **tunnel DNS** (T1071.004, T1048) encode des données dans les sous-domaines : labels longs (ici des chaînes hexadécimales de 44 caractères), forte cardinalité de noms uniques et un même domaine parent. La requête extrait le domaine enregistré (deux derniers labels) et la longueur du premier label. Bonne(s) réponse(s) : exfil-data.net, interrogé par 10.0.4.25 avec des sous-domaines d'environ 44 caractères, tous différents. — détails : question n° 266 du guide.

N°	Réponse	Justification
17	**A**	Séparer l'accès à certaines tables dans un espace partagé → RBAC au niveau table (ou contexte de ressource), pas un nouveau rôle Sentinel global. **Explication complémentaire :** Le **RBAC au niveau table** de Log Analytics permet d'accorder l'accès à des tables précises (ou de l'interdire) au sein d'un même espace. C'est l'option documentée pour séparer des données sensibles sans multiplier les espaces. Bonne(s) réponse(s) : Configurer un contrôle d'accès au niveau table (table-level RBAC), via un rôle personnalisé ou l'attribution de droits de lecture limités aux tables autorisées. — détails : question n° 12 du guide.
18	**D**	Liste de contrôle par type d'incident = tâches d'incident ajoutées par règle d'automatisation. Bonne(s) réponse(s) : Une règle d'automatisation avec l'action « Ajouter une tâche », conditionnée aux incidents d'hameçonnage. — détails : question n° 55 du guide.
19	**B**	Un implant trouvé = pivoter sur ses IOC dans tout le parc (chasse avancée) avant d'éradiquer. Bonne(s) réponse(s) : Extraire les indicateurs (hachage du binaire/DLL, IP et domaines de C2, nom de canal nommé, ligne de commande) et les rechercher dans tout le parc via la chasse avancée, puis isoler les appareils trouvés. — détails : question n° 312 du guide.
20	**B**	Même facilité dans les DCR Syslog et CEF = doublons ; attribuez une facilité distincte aux flux CEF. **Explication complémentaire :** Les DCR **Syslog** et **CEF** s'appuient sur les facilités/niveaux de gravité Syslog. Si les deux DCR sont associées au même redirecteur et ciblent la même facilité (par exemple *local4*), chaque message est envoyé dans les deux tables. Bonne(s) réponse(s) : Deux DCR (Syslog via AMA et CEF via AMA) collectent la même facilité Syslog sur le même redirecteur. — détails : question n° 20 du guide.
21	**D**	Faux positif récurrent = corriger la règle (exclusion ciblée par watchlist), pas fermer à la main. Bonne(s) réponse(s) : Corriger la règle : exclure les plages IP du VPN d'entreprise via une watchlist référencée dans la requête, puis documenter la modification. — détails : question n° 286 du guide.
22	**B**	Nouveauté par utilisateur = référence `make_set` sur une période passée + `set_has_element`. **Explication complémentaire :** On construit une **référence** (pays connus par utilisateur sur la période J-15 à J-1), puis on compare les connexions du dernier jour avec `set_has_element`. La jointure **inner** ignore les nouveaux utilisateurs sans historique (choix à assumer : un `leftouter` les inclurait). Bonne(s) réponse(s) : ```kql — détails : question n° 225 du guide.
23	**A**	Compte leurre = balise Honeytoken dans MDI → alerte à la moindre utilisation. Bonne(s) réponse(s) : Marquer le compte avec la balise « Honeytoken » dans Defender for Identity ; toute authentification ou activité sur ce compte déclenche une alerte. — détails : question n° 141 du guide.
24	**D**	Événements manqués par une règle mais visibles plus tard = délai d'ingestion → lookback élargi + ingestion_time(). **Explication complémentaire :** Les événements arrivés **après** l'exécution de la règle mais horodatés dans une fenêtre déjà analysée ne sont jamais évalués. La correction documentée : fenêtre = fréquence + délai, et `where ingestion_time() > ago(fréquence)`. Bonne(s) réponse(s) : Un délai d'ingestion supérieur à la fenêtre de la règle ; élargir la fenêtre de recherche (fréquence + délai) et filtrer sur `ingestion_time()` pour éviter les doublons. — détails : question n° 441 du guide.
25	**D**	SecurityIncident (comme SecurityAlert pour les mises à jour d'état) est historisée : toujours dédupliquer avec `arg_max(...)` par identifiant d'incident. Bonne(s) réponse(s) : Chaque modification d'un incident ajoute une nouvelle ligne dans SecurityIncident ; il faut ne conserver que la dernière version de chaque incident (par exemple avec `arg_max`). — détails : question n° 7 du guide.
26	**A**	Travail SecOps hors incident = cas générique ; incidents = cas d'incident (préversion). Bonne(s) réponse(s) : Les cas génériques (generic cases) de la gestion des cas du portail Defender. — détails : question n° 288 du guide.
27	**C**	Règle de transfert = T1114.003 ; règle de dissimulation = T1564.008. Bonne(s) réponse(s) : T1114.003 – Email Collection : Email Forwarding Rule (tactique Collection). — détails : question n° 345 du guide.
28	**A**	Indicateur de fichier = AV Defender actif + protection cloud ; SHA-256 prioritaire sur SHA-1 et MD5. Bonne(s) réponse(s) : L'antivirus Microsoft Defender n'est pas en mode actif (par exemple mode passif à cause d'un antivirus tiers) ou la protection cloud est désactivée. — détails : question n° 88 du guide.

N°	Réponse	Justification
29	D	Séparer les incidents par périmètre régional = « Restrict correlation to within scoped device groups » (au prix d'une vision moins globale). **Explication complémentaire :** Cette option limite la **corrélation des alertes en incidents** aux alertes provenant d'appareils d'un même groupe d'appareils, ce qui préserve la séparation des périmètres régionaux. Bonne(s) réponse(s) : « Restrict correlation to within scoped device groups » (restreindre la corrélation aux groupes d'appareils de l'étendue). — détails : question n° 98 du guide.
30	B	Action automatique = détection à très haute confiance ; affiner avant d'automatiser l'isolation. **Explication complémentaire :** Les **actions automatiques** (isolation, quarantaine) doivent reposer sur des détections à **très faible taux de faux positifs**. PsExec est un outil d'administration légitime : la détection doit cibler un contexte suspect (compte inhabituel, source inconnue, binaire renommé, cible sensible). Bonne(s) réponse(s) : Affiner la requête (exclure les comptes et serveurs de déploiement légitimes, cibler des combinaisons suspectes), et réserver l'isolation automatique aux détections à très haute confiance ; libérer les serveurs après vérification. — détails : question n° 450 du guide.
31	C	Réduire ce qui est ingéré = filtrer à la source (DCR XPath/facilités) ou transformer à l'ingestion (transformKql) ; filtrer dans les requêtes ne réduit pas la facture. **Explication complémentaire :** Les **transformations d'ingestion** sont des requêtes KQL appliquées dans la **DCR** avant stockage. Elles peuvent filtrer des lignes (`where`), supprimer ou masquer des colonnes (`project-away`, `extend` + `replace_string`) ou enrichir des données. Bonne(s) réponse(s) : Ajouter une transformation au moment de l'ingestion (transformKql) dans la DCR, par exemple `source | project-away AdditionalExtensions`. — détails : question n° 34 du guide.
32	C	Persistance applicative = ajout d'identifiants à une application (AuditLogs) → vérifier ses connexions et appels Graph. **Explication complémentaire :** L'ajout de **secrets ou certificats** à une application ou un principal de service (« Add service principal credentials », « Update application – Certificates and secrets management ») permet à un attaquant de s'authentifier comme l'application, souvent avec des permissions Graph élevées, indépendamment des utilisateurs. Bonne(s) réponse(s) : Une ligne : l'ajout d'identifiants à « App-Paie-Graph » par it.contractor@contoso.com depuis 203.0.113.66 à 04 h 12. — détails : question n° 272 du guide.
33	B	Résultats de chasse → Take action (appareils, fichiers, e-mails, utilisateurs) ; tout est tracé dans l'Action center. Bonne(s) réponse(s) : Oui : la fonctionnalité « Prendre des mesures » (Take action) des résultats de chasse avancée permet d'appliquer des actions sur les appareils (isolation, analyse antivirus, package d'investigation…) et sur les fichiers (quarantaine, indicateur). — détails : question n° 85 du guide.
34	C	Accès suspect au stockage : identifier le type d'authentification, mesurer les accès, faire tourner clés/SAS, restreindre le réseau. **Explication complémentaire :** L'**authentification** détermine la remédiation : une **clé de compte** ou un **SAS** divulgués doivent être **renouvelés/révoqués** ; une identité Entra compromise doit être traitée côté identité. Les **journaux de ressources** (StorageBlobLogs) indiquent les opérations, objets et volumes. Bonne(s) réponse(s) : Identifier le mode d'authentification utilisé (clé de compte, SAS, Entra ID), les objets consultés et le volume (StorageBlobLogs), l'origine de l'identifiant (fuite de clé/SAS dans un dépôt de code, identité compromise), puis faire tourner les clés/SAS et restreindre l'accès réseau. — détails : question n° 382 du guide.
35	B	Appliance CEF → redirecteur Linux + AMA + DCR « CEF via AMA » → CommonSecurityLog ; Syslog classique → table Syslog. Bonne(s) réponse(s) : Un redirecteur de journaux Linux avec l'agent Azure Monitor et une DCR « CEF via AMA », vers lequel le pare-feu envoie ses messages Syslog/CEF ; les données arrivent dans CommonSecurityLog. — détails : question n° 19 du guide.
36	C	Vidage LSASS = procdump -ma lsass / rundll32 comsvcs MiniDump ; prévenir avec ASR et Credential Guard. **Explication complémentaire :** Le vidage de LSASS permet d'extraire des identifiants. Les variantes « living off the land » utilisent **procdump** (Sysinternals) ou **comsvcs.dll MiniDump** via rundll32. Bonne(s) réponse(s) : ```kqlx — détails : question n° 224 du guide.
37	B	Les tables Device* embarquent le processus initiateur et son parent : éviter les jointures inutiles. Bonne(s) réponse(s) : ```kqlx — détails : question n° 239 du guide.
38	B	Poste à vol d'identifiants : réinitialiser tous les comptes connectés depuis la compromission. **Explication complémentaire :** **DeviceLogonEvents** liste les ouvertures de session réussies sur l'appareil ; tous les comptes connectés après la compromission (interactifs, RDP, services, mais aussi réseau selon les techniques) peuvent avoir leurs identifiants en mémoire et doivent être réinitialisés. Bonne(s) réponse(s) : ```kqlx — détails : question n° 429 du guide.

N°	Réponse	Justification
39	**A**	Moins d'incidents sans perdre d'alertes = regroupement d'alertes (période ≤ 7 jours, entités choisies, réouverture optionnelle). **Explication complémentaire :** Dans l'onglet **Paramètres d'incident** d'une règle planifiée, le **regroupement d'alertes** permet de rattacher les alertes à un même incident selon : toutes les entités correspondantes, des **entités sélectionnées** (ici Host), ou tous les détails. On fixe la **période** (jusqu'à 7 jours) et l'option **« Rouvrir les incidents correspondants fermés »**. Bonne(s) réponse(s) : Activer le regroupement d'alertes dans les paramètres d'incident, sur une période de 24 heures, en regroupant les alertes dont l'entité Host correspond, avec l'option de réouverture des incidents fermés correspondants. — détails : question n° 41 du guide.
40	**D**	Conteneur privilégié + évasion = isoler la charge, examiner le nœud, trouver qui a déployé, durcir l'admission. **Explication complémentaire :** Un **conteneur privilégié** permet d'accéder aux ressources de l'hôte ; une **tentative d'évasion** (T1611 – Escape to Host) indique une progression vers le nœud. La réponse cible la charge, le nœud et le vecteur (identité ou pipeline ayant déployé le pod). Bonne(s) réponse(s) : Isoler la charge (supprimer ou mettre à l'échelle zéro le pod, appliquer une politique réseau restrictive), examiner le nœud (possible compromission de l'hôte), identifier qui a déployé le conteneur et renforcer les politiques d'admission (interdire les conteneurs privilégiés). — détails : question n° 386 du guide.
41	**A, C**	Vérifier l'exfiltration : volumes réseau sortants + outils d'archivage/transfert (rclone, 7-Zip…). Bonne(s) réponse(s) : L'exécution d'outils de synchronisation/archivage (rclone, MEGAsync, 7-Zip, WinRAR) dans DeviceProcessEvents sur les serveurs de fichiers. / Les journaux réseau (pare-feu/proxy, DeviceNetworkEvents) pour des volumes sortants inhabituels vers des services de stockage ou des IP inconnues. — détails : question n° 311 du guide.
42	**C, E**	Compte de messagerie compromis : identifiants + sessions + MFA, puis règles/transferts/délégations et purge des messages. **Explication complémentaire :** La procédure Microsoft « Répondre à un compte de messagerie compromis » prévoit de **réinitialiser le mot de passe**, **révoquer les sessions**, vérifier/retirer les **méthodes d'authentification** ajoutées, **supprimer les règles** de boîte de réception et de transfert suspectes, vérifier les **délégations** et le **transfert SMTP** de la boîte, débloquer l'envoi si l'utilisateur a été restreint, et purger les messages malveillants. Bonne(s) réponse(s) : Supprimer les règles de boîte de réception et de transfert malveillantes, et retirer les e-mails malveillants envoyés en interne. / Réinitialiser le mot de passe, révoquer les sessions/jetons d'actualisation et vérifier les méthodes MFA enregistrées par l'attaquant. — détails : question n° 135 du guide.
43	**B**	Portail Defender : ne pas baser l'automatisation sur le titre des incidents ; utiliser règle d'analyse, alertes, balises. **Explication complémentaire :** Dans le portail Defender, la création et le **nommage des incidents** sont gérés par la corrélation Defender XDR, qui peut fusionner des alertes et attribuer un titre décrivant l'attaque. Microsoft recommande de revoir les règles d'automatisation qui s'appuient sur le **titre** ou le **fournisseur d'incident**, et de privilégier des conditions sur le **nom de la règle d'analyse**, les **noms d'alertes**, les **balises** ou les entités. Bonne(s) réponse(s) : Le moteur de corrélation Defender XDR peut renommer les incidents et en modifier la composition ; les conditions fondées sur le titre de l'incident ne sont plus fiables et doivent être remplacées par des conditions sur la règle d'analyse, les alertes ou les balises. — détails : question n° 58 du guide.
44	**D**	Persistance résistante : examiner les abonnements WMI ; règle ASR dédiée pour la bloquer. **Explication complémentaire :** La **persistance WMI** (T1546.003) associe un **filtre** d'événement (par exemple « toutes les 60 s » ou « au démarrage »), un **consommateur** (CommandLineEventConsumer, ActiveScriptEventConsumer) et une **liaison**. Elle survit aux redémarrages et échappe aux contrôles classiques. Bonne(s) réponse(s) : Les abonnements aux événements WMI (filtres, consommateurs et liaisons), que la règle ASR « Bloquer la persistance via un abonnement aux événements WMI » permet de bloquer. — détails : question n° 318 du guide.
45	**C**	P1 = EDR MDE ; P2 = P1 + sans agent, FIM, JIT, DNS, 500 Mo d'ingestion. Bonne(s) réponse(s) : Defender for Servers Plan 2. — détails : question n° 355 du guide.
46	**D**	Suppressions SharePoint/OneDrive = OfficeActivity (FileDeleted, FileRecycled…). Bonne(s) réponse(s) : ```kql — détails : question n° 232 du guide.
47	**A**	Accès SYSTEM prolongé = reconstruire depuis une source fiable plutôt que nettoyer. **Explication complémentaire :** Après une compromission avec **privilèges élevés prolongés**, la **reconstruction** est la seule option offrant une confiance raisonnable. Le nettoyage ciblé convient aux infections limitées et bien comprises (par exemple un malware de base bloqué rapidement). Bonne(s) réponse(s) : Reconstruire (réinstaller) le serveur à partir d'une source fiable et restaurer les données vérifiées, car un accès SYSTEM prolongé ne permet pas de garantir que toutes les modifications ont été identifiées. — détails : question n° 332 du guide.

N°	Réponse	Justification
48	**C**	Application OAuth malveillante = désactiver/interdire l'application et révoquer les consentements ; le changement de mot de passe ne suffit pas. **Explication complémentaire :** Le **consentement illicite** (T1528) permet à une application malveillante d'accéder aux données des utilisateurs via des **jetons OAuth**, indépendamment de leur mot de passe. Defender for Cloud Apps (gouvernance des applications) permet d'**examiner** l'application et de la **désactiver** ou d'**interdire** son usage, ce qui révoque son accès. Bonne(s) réponse(s) : Examiner l'application (éditeur, autorisations, activité, utilisateurs), et si elle est malveillante, l'interdire/la désactiver et révoquer les consentements, puis enquêter sur les données consultées. — détails : question n° 152 du guide.
49	**A**	Classeur interactif = paramètres `{NomParametre}` ; période = Time range picker. Bonne(s) réponse(s) : Créer un paramètre de type « Time range picker » (par exemple TimeRange) et utiliser ce paramètre dans les requêtes, par exemple `where TimeGenerated {TimeRange}` ou en le sélectionnant comme intervalle de la requête. — détails : question n° 62 du guide.
50	**C**	Clé Run + RegistryValueSet + chemin inscriptible = persistance (T1547.001). Bonne(s) réponse(s) : ```kqlx — détails : question n° 223 du guide.

Le score obtenu à cet examen blanc est un indicateur d'entraînement : il ne constitue en aucun cas une prédiction du résultat à l'examen officiel, dont le format, la pondération et la notation (score minimal de 700 sur 1000) sont définis par Microsoft.

Examen blanc n° 3 — corrigé

Corrigé de l'examen blanc n° 3

Chaque question de cet examen est une reprise d'une question du guide (numéro indiqué) ; les propositions ont été mélangées. Elle n'est pas comptée une seconde fois dans le total des questions uniques.

N°	Réponse	Justification
1	**A**	Messagerie potentiellement compromise → communication hors bande prévue dans le plan. Bonne(s) réponse(s) : Utiliser un canal de communication hors bande prédéfini (par exemple téléphonie ou outil de collaboration indépendant du locataire compromis). — détails : question n° 281 du guide.
2	**A**	SecurityAlert.Entities = JSON → todynamic + mv-expand pour extraire les comptes. Bonne(s) réponse(s) : ```kql — détails : question n° 246 du guide.
3	**A, C**	Compromission applicative : retirer le secret ajouté, confiner le compte humain, faire tourner les secrets exfiltrés. Bonne(s) réponse(s) : Confiner le compte administrateur compromis (mot de passe, révocation des sessions, retrait temporaire des rôles). / Supprimer le secret ajouté (et faire tourner les autres identifiants de l'application), et faire tourner les secrets du coffre qui ont été lus. — détails : question n° 444 du guide.
4	**A**	Connexion Sentinel → Defender : Owner (ou User Access Administrator + Sentinel Contributor) sur l'abonnement + Security Administrator Entra si plusieurs espaces. Aucune licence E5 requise. Bonne(s) réponse(s) : Le rôle Propriétaire (attribution inconditionnelle) sur l'abonnement — ou Administrateur de l'accès utilisateur et Microsoft Sentinel Contributor — ainsi qu'au moins le rôle Administrateur de la sécurité dans Microsoft Entra ID. — détails : question n° 8 du guide.
5	**A**	Qualifier une localisation inhabituelle = comparer IP, appareil, conformité, agent utilisateur, application. Bonne(s) réponse(s) : ```kql — détails : question n° 418 du guide.
6	**B**	Attaque hybride = Defender XDR (corrélation) + Sentinel (journaux de plateforme), unifiés dans le portail Defender. **Explication complémentaire :** Une attaque **hybride** traverse terminaux, identités locales et cloud, et ressources Azure. **Defender XDR** corrèle les signaux de ses produits ; **Sentinel** apporte les journaux de plateforme (AuditLogs, AzureActivity, journaux de ressources) et des corrélations sur mesure. Bonne(s) réponse(s) : Defender XDR (MDE, MDI, MDCA, Entra ID Protection) pour la corrélation des alertes en un incident, et Microsoft Sentinel pour les journaux Entra ID (AuditLogs), Azure (AzureActivity) et les corrélations personnalisées, dans le portail Defender unifié. — détails : question n° 337 du guide.
7	**B, D**	Prévention des fuites : DLP fondée sur les étiquettes + blocage des applications non approuvées. Bonne(s) réponse(s) : Le blocage des applications de stockage personnel non approuvées via Defender for Cloud Apps et Defender for Endpoint. / Des stratégies DLP (Microsoft 365 et terminaux) bloquant le partage et le chargement de contenus étiquetés « Confidentiel » vers des destinations non autorisées. — détails : question n° 436 du guide.
8	**C**	Journaux applicatifs personnalisés → table _CL + Logs Ingestion API + DCR (transformation possible) ; l'API HTTP Data Collector est historique. **Explication complémentaire :** La **Logs Ingestion API** permet d'envoyer des données via REST vers une **table personnalisée _CL** (ou certaines tables standard prises en charge). La **DCR** définit le flux d'entrée, la transformation KQL (`transformKql`) et la table de destination. Bonne(s) réponse(s) : Créer une table personnalisée (suffixe _CL) et utiliser l'API d'ingestion des journaux (Logs Ingestion API) avec un point de terminaison de collecte et une règle de collecte de données qui peut transformer les données. — détails : question n° 23 du guide.
9	**C**	Exfiltration réseau = sum(SentBytes) privé → public ; ipv4_is_private() pour classer les adresses. Bonne(s) réponse(s) : ```kql — détails : question n° 230 du guide.
10	**A**	`between (a .. b)` avec des bornes datetime UTC. Bonne(s) réponse(s) : `| where TimeGenerated between (datetime(2026-10-01 08:00) .. datetime(2026-10-01 12:00))` — détails : question n° 206 du guide.
11	**B, C**	Defender for Containers = posture K8s + vulnérabilités des images + détection à l'exécution. Bonne(s) réponse(s) : L'évaluation des vulnérabilités des images de conteneurs (registres et images en cours d'exécution) et le durcissement de la posture Kubernetes. / La détection des menaces à l'exécution sur les nœuds et le plan de contrôle Kubernetes (par exemple conteneur privilégié, exécution de commandes suspectes, accès à l'API depuis une IP malveillante). — détails : question n° 367 du guide.

N°	Réponse	Justification
12	**B**	Fermer automatiquement les alertes « sans menace » après AIR = Automatically resolve alerts. Bonne(s) réponse(s) : « Automatically resolve alerts » (résoudre automatiquement les alertes). — détails : question n° 119 du guide.
13	**D**	Minage sur des VM nouvelles = identifiants de création de ressources compromis (T1496) → AzureActivity. Bonne(s) réponse(s) : La compromission d'une identité ou d'un secret disposant de droits de création de ressources (Resource Hijacking, T1496), à vérifier dans AzureActivity (créations de VM, appelant, IP). — détails : question n° 383 du guide.
14	**B**	Historiser/transmettre alertes et recommandations = export continu (Log Analytics, Event Hubs). Bonne(s) réponse(s) : L'export continu (continuous export) vers Log Analytics et/ou Event Hubs. — détails : question n° 379 du guide.
15	**A**	Priorité = impact (actifs/comptes critiques, étendue) × urgence (attaque active, non contenue). Bonne(s) réponse(s) : L'incident 2, car il indique une compromission probable d'identifiants à privilèges élevés avec un impact potentiel sur tout le domaine. — détails : question n° 279 du guide.
16	**B**	Donner à une équipe l'accès à « ses » journaux seulement → RBAC de contexte de ressource. Bonne(s) réponse(s) : Le RBAC de contexte de ressource : l'équipe consulte les journaux depuis ses ressources Azure, sur lesquelles elle possède déjà des droits. — détails : question n° 13 du guide.
17	**A, E**	Connecteur Defender XDR = incidents/alertes (bidirectionnel) + événements bruts de chasse avancée optionnels. Bonne(s) réponse(s) : Les événements bruts de la chasse avancée (par exemple DeviceProcessEvents, EmailEvents, IdentityLogonEvents) vers les tables correspondantes de l'espace. / Les incidents et alertes de Defender XDR, synchronisés avec Sentinel. — détails : question n° 24 du guide.
18	**C**	Faux positifs VPN = déclarer les IP de sortie comme emplacements de confiance (Entra) / plages d'entreprise (MDCA). Bonne(s) réponse(s) : Déclarer les plages IP de sortie du VPN comme emplacements nommés de confiance (Entra ID) et comme plages d'entreprise dans Defender for Cloud Apps. — détails : question n° 421 du guide.
19	**C**	Patient zéro = première occurrence chronologique des indicateurs et de l'activité du compte, pas l'appareil le plus bruyant. **Explication complémentaire :** Le **patient zéro** se déduit de la **chronologie** : premières occurrences des IOC (hachages, IP, domaines), première activité du compte compromis, origine des connexions latérales (DeviceLogonEvents RemoteIP, DeviceFileEvents RequestSourceIP). La chasse avancée avec `min(Timestamp)` par appareil aide à ordonner les événements. Bonne(s) réponse(s) : Reconstituer la chronologie à partir des premiers horodatages d'activité malveillante (première exécution des IOC, première connexion du compte compromis, premier e-mail ouvert), en remontant l'arborescence des processus et les connexions latérales jusqu'à l'activité la plus ancienne. — détails : question n° 348 du guide.
20	**C**	Détections versionnées et déployées automatiquement = Repositories (GitHub / Azure DevOps). Bonne(s) réponse(s) : Les référentiels (Repositories) de Microsoft Sentinel, connectés à GitHub ou Azure DevOps, qui déploient le contenu à chaque validation. — détails : question n° 74 du guide.
21	**A**	AIR = collecte de preuves → verdicts → remédiations automatiques ou en attente (Action center). Bonne(s) réponse(s) : Une alerte déclenche une enquête automatisée qui examine les preuves (fichiers, processus, services, pilotes, adresses IP, e-mails…), leur attribue un verdict et propose ou applique des actions de remédiation selon le niveau d'automatisation. — détails : question n° 116 du guide.
22	**A**	Boucles d'automatisation = conditions de mise à jour trop larges ; cibler le champ modifié. **Explication complémentaire :** Les déclencheurs « à la mise à jour » peuvent réagir aux changements effectués par d'autres règles. Des **conditions précises** sur le type de mise à jour (champ modifié, valeur) évitent les **boucles**. Bonne(s) réponse(s) : Restreindre les conditions des règles déclenchées à la mise à jour (par exemple « Statut modifié en Actif » ou « Alertes ajoutées ») pour qu'une modification faite par une règle ne déclenche pas l'autre en boucle. — détails : question n° 449 du guide.
23	**D**	AV tiers + Defender en passif → activer EDR in block mode pour la remédiation post-violation. Bonne(s) réponse(s) : Le mode bloc EDR (EDR in block mode). — détails : question n° 95 du guide.
24	**A**	T1490 = vssadmin/wmic/bcdedit/wbadmin ; signal fort de rançongiciel imminent. Bonne(s) réponse(s) : ```kqlx — détails : question n° 221 du guide.
25	**D, E**	Office → PowerShell : règle ASR en Bloquer + protection de la messagerie. Bonne(s) réponse(s) : Renforcer la protection de la messagerie : pièces jointes sécurisées, blocage des macros provenant d'Internet et stratégies prédéfinies Standard/Strict. / Activer en mode Bloquer la règle ASR « Bloquer toutes les applications Office pour créer des processus enfants » (après audit). — détails : question n° 411 du guide.

N°	Réponse	Justification
26	**B**	Impact = ce que le compte compromis a réellement consulté/modifié pendant la fenêtre de compromission, d'après les journaux. Bonne(s) réponse(s) : Recenser les ressources et données auxquelles le compte a accédé pendant la période de compromission (journaux d'audit Microsoft 365, accès aux fichiers, e-mails consultés, applications), et les privilèges qu'il détient. — détails : question n° 283 du guide.
27	**D**	ASR : toujours Audit d'abord, puis exclusions ciblées, puis Bloquer/Avertir par vagues. Bonne(s) réponse(s) : Déployer les règles en mode Audit, analyser les événements (rapports ASR, chasse avancée) pendant une période représentative, créer les exclusions nécessaires, puis passer en mode Bloquer (ou Avertir) par vagues. — détails : question n° 90 du guide.
28	**B, E**	Après un AiTM : stratégies de risque + MFA résistante à l'hameçonnage + appareils conformes. Bonne(s) réponse(s) : Exiger une authentification résistante à l'hameçonnage (FIDO2/passkeys, Windows Hello) et des appareils conformes pour les rôles sensibles comme la comptabilité. / Activer les stratégies d'accès conditionnel basées sur le risque (connexion → MFA, utilisateur → changement de mot de passe sécurisé). — détails : question n° 406 du guide.
29	**C**	Liste d'IOC = datatable/watchlist + `has_any(liste)` sur RemoteUrl. Bonne(s) réponse(s) : ```kqlx — détails : question n° 229 du guide.
30	**C**	Rôles Azure RBAC = AzureActivity (roleAssignments/write) ; rôles Entra = AuditLogs. Bonne(s) réponse(s) : ```kql — détails : question n° 227 du guide.
31	**D**	MDI (requêtes vues par le DC) ⋈ MDE (processus du poste) = identification de l'outil de reconnaissance. **Explication complémentaire :** Defender for Identity voit les **requêtes LDAP** reçues par les contrôleurs de domaine (IdentityQueryEvents) avec le **poste source** ; MDE voit les **processus** de ce poste. La jointure sur le nom d'appareil et la fenêtre temporelle de l'activité LDAP identifient l'outil responsable. Bonne(s) réponse(s) : ```kqlx — détails : question n° 253 du guide.
32	**B**	Activité d'une session = DeviceId + LogonId (InitiatingProcessLogonId). **Explication complémentaire :** Le **LogonId** identifie une session d'ouverture sur un appareil ; les processus créés dans cette session portent le même identifiant dans **InitiatingProcessLogonId** (ou LogonId selon la colonne). La jointure sur **DeviceId + identifiant de session** isole précisément l'activité de la session RDP. Bonne(s) réponse(s) : ```kqlx — détails : question n° 244 du guide.
33	**C**	Volume facturable par type de données → table Usage (DataType, Quantity en Mo, IsBillable). Bonne(s) réponse(s) : ```kql — détails : question n° 33 du guide.
34	**D**	Sans MDO P2 : recherche de contenu Purview + `New-ComplianceSearchAction -Purge`. **Explication complémentaire :** La **recherche de contenu** (eDiscovery) identifie les messages ; la cmdlet ** `New-ComplianceSearchAction -Purge -PurgeType SoftDelete|HardDelete` ** les supprime. Cette méthode est disponible sans MDO P2, avec des limites (nombre d'éléments supprimés par boîte et par action). Bonne(s) réponse(s) : Créer une recherche de contenu Microsoft Purview (eDiscovery) ciblant le message (expéditeur, objet, date), puis lancer une action de purge (`New-ComplianceSearchAction -Purge`) en suppression réversible ou définitive. — détails : question n° 169 du guide.
35	**D**	Santé de Sentinel = SentinelHealth (connecteurs, règles, playbooks) + SentinelAudit (changements). Bonne(s) réponse(s) : L'audit et la surveillance de l'intégrité de Microsoft Sentinel, qui alimentent les tables SentinelHealth et SentinelAudit, puis des règles d'analyse sur ces tables. — détails : question n° 72 du guide.
36	**A**	Pas d'entités = pas de corrélation ni de pivot : mappez Account, Host, IP… avec des identificateurs forts (10 entités max par règle). Bonne(s) réponse(s) : Le mappage des entités (Account, Host, IP…) vers les colonnes de résultat de la requête. — détails : question n° 39 du guide.
37	**C, D**	Campagne d'hameçonnage = purger les messages + bloquer expéditeur/domaine/URL (TABL + indicateurs). Bonne(s) réponse(s) : Bloquer l'expéditeur, le domaine et l'URL dans la liste d'autorisation/blocage du locataire (et via des indicateurs MDE pour l'URL). / Retirer les messages distribués (Threat Explorer / chasse avancée, action de remédiation suivie dans le Centre de notifications). — détails : question n° 295 du guide.
38	**D**	Faux dirigeants / domaines ressemblants = protection contre l'usurpation d'identité (anti-phishing MDO). Bonne(s) réponse(s) : La protection contre l'usurpation d'identité d'utilisateurs et de domaines dans la stratégie anti-hameçonnage, avec le directeur financier comme utilisateur protégé et les domaines de l'organisation comme domaines protégés. — détails : question n° 130 du guide.

N°	Réponse	Justification
39	C	Télémétrie MDE supplémentaire ciblée → collecte de données personnalisée (balises dynamiques → tables DeviceCustom* dans Sentinel). **Explication complémentaire :** La **collecte de données personnalisée** permet de définir des **règles** (filtres sur chemins, noms de processus, connexions réseau…) qui collectent des événements supplémentaires sur des appareils ciblés par **balises dynamiques**, et de les router vers **Microsoft Sentinel** dans des tables dédiées (DeviceCustomProcessEvents, DeviceCustomNetworkEvents, etc.). Bonne(s) réponse(s) : La collecte de données personnalisée de Defender for Endpoint : des règles ciblant les appareils par balises dynamiques, envoyant les événements dans des tables dédiées (par exemple DeviceCustomNetworkEvents) de l'espace Sentinel. — détails : question n° 96 du guide.
40	D	Portail Defender = moteur de corrélation XDR unique pour les alertes Sentinel et Defender ; attendez-vous à des incidents multi-produits. Bonne(s) réponse(s) : Le moteur de corrélation de Defender XDR crée et regroupe les incidents à partir des alertes Sentinel et Defender, au lieu de la logique de création d'incidents propre à Sentinel. — détails : question n° 4 du guide.
41	C	Chasse structurée (hypothèse, requêtes, signets, conclusions) = Hunts. Bonne(s) réponse(s) : Les chasses (Hunts) de Microsoft Sentinel. — détails : question n° 64 du guide.
42	C	Pas de retard de remise tout en analysant les pièces jointes = Dynamic Delivery. Bonne(s) réponse(s) : La remise dynamique (Dynamic Delivery). — détails : question n° 126 du guide.
43	C	Session illégitime confirmée : marquer compromis, révoquer, réinitialiser, mesurer l'impact. Bonne(s) réponse(s) : Confirmer la compromission (marquer l'utilisateur compromis), révoquer les sessions, réinitialiser les identifiants et examiner les accès OneDrive depuis cette IP. — détails : question n° 419 du guide.
44	D	Force brute RDP réussie : contenir, invalider les identifiants, investiguer, puis fermer l'exposition (JIT/Bastion). Bonne(s) réponse(s) : Contenir la VM (restreindre le NSG/isoler via MDE), désactiver ou réinitialiser le compte compromis, investiguer l'activité post-connexion (processus, persistance), puis fermer l'exposition (JIT ou Bastion). — détails : question n° 376 du guide.
45	B	MFA effective = SigninLogs.AuthenticationRequirement ; rôles = IdentityInfo.AssignedRoles. Bonne(s) réponse(s) : ```kql — détails : question n° 250 du guide.
46	C	Ports de gestion exposés = JIT (ouverture temporaire, IP source, durée limitée) ou Bastion. Bonne(s) réponse(s) : L'accès juste-à-temps (JIT), qui ferme les ports de gestion par défaut et ne les ouvre, sur demande approuvée, que pour une durée et une IP source limitées. — détails : question n° 357 du guide.
47	C	Optimisation des coûts et de la couverture = page « Optimisations SOC ». Bonne(s) réponse(s) : Les optimisations SOC (SOC optimization) de Microsoft Sentinel. — détails : question n° 32 du guide.
48	C	Implant actif (C2 + persistance) = isoler d'abord, collecter ensuite. Bonne(s) réponse(s) : Isoler PC-0423 via MDE (isolation complète), puis collecter le package d'investigation. — détails : question n° 408 du guide.
49	D	Portail Defender : un locataire, un espace principal, des espaces secondaires. **Explication complémentaire :** La documentation indique que le portail Defender prend en charge **un locataire Microsoft Entra** avec **un espace principal et plusieurs espaces secondaires**. Si un seul espace est connecté, il devient automatiquement principal. Bonne(s) réponse(s) : Un espace est désigné comme espace principal ; les autres sont connectés comme espaces secondaires, et les incidents et la chasse avancée tiennent compte de cette organisation. — détails : question n° 75 du guide.
50	B	Alertes multicloud + terminal = un incident : révoquer les clés cloud, restaurer la journalisation, isoler le poste. **Explication complémentaire :** Defender for Cloud **multicloud** analyse les événements **AWS CloudTrail** (selon les plans activés) et génère des alertes, corrélées dans Defender XDR avec les autres signaux. Le vol d'identifiants sur un poste de développeur expose souvent des **clés cloud** (fichiers de configuration, variables d'environnement). Bonne(s) réponse(s) : Traiter les deux alertes comme un même incident probable : désactiver la clé d'accès AWS compromise, réactiver la journalisation CloudTrail, isoler le poste du développeur, puis rechercher d'autres secrets cloud exposés sur ce poste. — détails : question n° 394 du guide.

Le score obtenu à cet examen blanc est un indicateur d'entraînement : il ne constitue en aucun cas une prédiction du résultat à l'examen officiel, dont le format, la pondération et la notation (score minimal de 700 sur 1000) sont définis par

Microsoft.